

The State of OpenClaw Security

Threats, Vulnerabilities, and the Case for
Continuous Agent Hardening

February 2026

clawscan.app

180,000+ deployments worldwide | 512 known vulnerabilities | 21,639 exposed instances
341 malicious skills identified | 1.5M+ tokens leaked in documented breaches

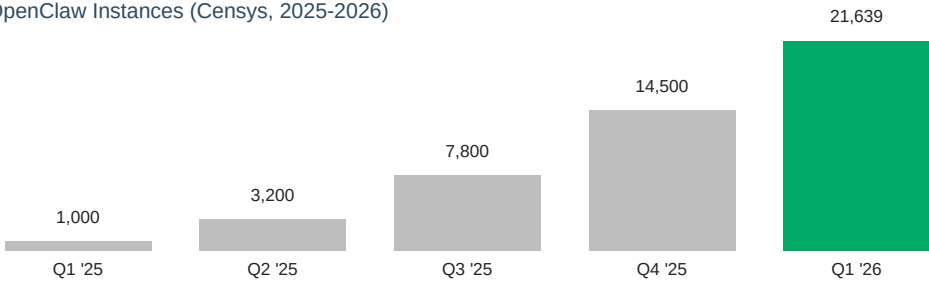
A critical vulnerability (CVSS 9.8) allowed unauthenticated attackers to bypass Gateway access controls, enabling full agent takeover. All versions prior to 0.14.2 were affected.

Cisco Talos documented ClawHavoc, a post-exploitation framework that automates reconnaissance, credential harvesting, and lateral movement through OpenClaw agent networks.

Internet-wide scanning revealed 21,639 exposed instances, many running default configurations with no authentication -- a 20x increase from early 2025.

Threat actors exfiltrated 1.5M+ tokens including API keys and PII from a misconfigured skill with unrestricted file system access.

Exposed OpenClaw Instances (Censys, 2025-2026)



"AI agent frameworks represent the next frontier of enterprise attack surface. Organizations deploying without continuous security monitoring face risks comparable to early cloud adoption without proper controls." -- Cisco Talos, 2026

OpenClaw deployments expose a multi-layered attack surface extending well beyond traditional application security.

Layer	Domain	Key Threat Vectors
1	Gateway Authentication	Token validation, session management, access control bypass
2	Skill & Plugin Security	Malicious skills, permission escalation, supply chain attacks
3	Agent Configuration	Model access controls, tool permissions, prompt injection
4	Data Flow & Exfiltration	Token leakage, PII exposure, unencrypted channel data
5	Network Exposure	Public-facing gateways, default ports, missing TLS
6	Infrastructure Hardening	Container isolation, resource limits, secrets management
7	Monitoring & Response	Audit logging, anomaly detection, incident response

Conventional scanners were built for static applications and well-defined perimeters. Agent frameworks break these assumptions.

Dimension	Traditional Tools	ClawScan
Scope	Network, OS, application layers	All 7 agent-specific layers
Agent awareness	Treats agents as black boxes	Purpose-built for OpenClaw
Skill analysis	No concept of skills/plugins	Scans permissions, provenance
Configuration	Generic CIS benchmarks	OpenClaw-specific checks
Token detection	Static regex patterns	Context-aware token flow analysis
Speed	Hours to configure	Single command, seconds to results
Maintenance	Signature updates, rule tuning	Continuous threat research updates

The gap is structural, not incremental. Traditional tools lack the semantic understanding of agent architectures required to identify these vulnerability classes.

Category	Checks	Points
Gateway Security	Auth, TLS, rate limiting, CORS, token rotation	25
Skill Integrity	Provenance, permissions, malicious signatures	25
Agent Configuration	Model access, tool restrictions, prompt guards	20
Data Protection	Secret exposure, PII handling, exfiltration vectors	15
Infrastructure	Network exposure, containers, logging, updates	15

```
$ clawscan scan --target gateway.example.com

ClawScan v1.2.0 -- OpenClaw Security Scanner
Target: gateway.example.com:3000
Checks: 24 total | 18 passed | 4 warnings | 2 failed
Score: 73 / 100
Grade: B
Report: https://clawscan.app/reports/a8f3e2d1
```

- Today:

Run clawscan scan on all exposed gateways. Revoke default tokens. Enable TLS.
- This Week:

Audit installed skills, remove unverified packages. Enable audit logging. Restrict model permissions.
- This Month:

Establish continuous scanning via ClawScan Pro. Implement network segmentation. Develop incident response playbook.

Community (Free)	Pro (\$19/mo)	Enterprise
5 scans / month	Unlimited scans	Unlimited scans
Basic checks (15/24)	All 24 checks	All + custom policies
CLI only	CLI + dashboard + API	CLI + dashboard + SSO
Community support	Email support, 24h SLA	Dedicated, 4h SLA
--	CI/CD integration	On-prem option
--	Historical trends	SOC 2, ISO compliance